

进一步定义存取权限。

[例 4.17] 建立计算机科学与技术专业学生的视图, 把对该视图的 SELECT 权限授予王平, 把该视图上的所有操作权限授予张明。

```
CREATE VIEW CS_Student    /* 先建立视图 CS_Student */
AS
SELECT *
FROM Student
WHERE Smajor='计算机科学与技术'
WITH CHECK OPTION;      /* 对该视图进行增、删、改时, 必须满足 */
                          /* Smajor='计算机科学与技术'的条件 */
GRANT SELECT              /* 王平老师只能查询计算机科学与技术学生的信息 */
ON CS_Student
TO 王平;
GRANT ALL PRIVILEGES     /* 专业负责人张明具有查询和增、删、改该视图的所有权限 */
ON CS_Student
TO 张明;
```

4.4 审 计

数据库安全审计系统提供了一种事后检查的安全机制。前面讲的用户身份鉴别、存取控制是数据库安全保护的重要技术(安全策略方面), 但不是全部。审计(audit)功能就是数据库管理系统达到 C2 以上安全级别必不可少的一项指标。

任何系统的安全保护措施都不是完美无缺的, 蓄意盗窃、破坏数据的人总是想方设法打破控制。审计功能把用户对数据库的所有操作自动记录下来放入审计日志(audit log)。审计员可以利用审计日志监控数据库中的各种行为, 重现导致数据库现有状况的一系列事件, 找出非法存取数据的人、时间和内容等; 还可以通过对审计日志分析, 对潜在的威胁提前采取措施加以防范。

审计通常是很费时间和空间的, 所以数据库管理系统往往都将审计设置为可选特征, 允许数据库管理员根据具体应用对安全性要求灵活地打开或关闭审计功能。审计功能主要用于安全性要求较高的部门。它能对普通和特权用户行为、各种表操作、身份鉴别、自主和强制访问控制等操作进行审计。它既能审计成功操作, 也能审计失败操作。

1. 审计事件

审计事件一般有多种类别, 例如:

① 服务器事件。审计数据库服务器发生的事件, 包含数据库服务器的启动、停止、数据库服务器配置文件的重新加载等。

② 系统权限。审计对系统拥有的结构或模式对象进行的操作，要求该操作的权限是通过系统权限获得的。

③ 语句事件。审计 SQL 语句，如 DDL、DML 及 DCL 语句。

④ 模式对象事件。审计特定模式对象上进行的 SELECT 或 DML 操作。模式对象包括表、视图、存储过程、函数等，但不包括依附于表的索引、约束、触发器、分区表等。

2. 审计功能

审计功能主要包括以下几方面内容：

① 基本功能。提供多种审计查阅方式：基本、可选、有限等。

② 提供多套审计规则。审计规则一般在数据库初始化时设定，以方便审计员管理。

③ 提供审计分析和报表功能。

④ 提供审计日志管理功能。主要包括为防止审计员误删审计记录，审计日志必须先转储后删除；对转储的审计记录文件提供完整性和保密性保护；只允许审计员查阅和转储审计记录，不允许任何用户新增和修改审计记录等。

系统提供查询审计设置及审计记录信息的专门视图。对于系统权限级别、语句级别及模式对象级别的审计记录，也可通过相关的系统表直接查看。

3. AUDIT 语句和 NOAUDIT 语句

AUDIT 语句用来设置审计功能，NOAUDIT 语句则用来取消审计功能。

审计一般可以分为用户级审计和系统级审计。用户级审计是任何用户可设置的审计，主要是用户针对自己创建的数据库表或视图进行审计，记录所有用户对这些表或视图的一切成功和（或）不成功的访问要求，以及各种类型的 SQL 操作。

系统级审计只能由数据库管理员设置，用以监测成功或失败的登录要求、监测授权和收回操作，以及其他数据库级权限下的操作。

[例 4.18] 对修改 SC 表结构或修改 SC 表数据的操作进行审计。

① 先显示当前审计开关状态。

```
SHOW AUDIT_TRAIL;
```

② 打开审计开关。

```
SET AUDIT_TRAIL TO ON;
```

③ 对 SC 表设置审计。

```
AUDIT ALTER, UPDATE ON SC BY ACCESS;
```

BY ACCESS 审计方式表示系统对每个设置的审计操作都要进行记录。BY SESSION 审计方式则表示对于每次会话中涉及的同类审计操作，系统只记录最早的一次。

[例 4.19] 取消对 SC 表的 ALTER 和 UPDAE 操作审计。

NOAUDIT ALTER, UPDATE ON SC;

审计设置以及审计日志一般都存储在数据字典中。必须把审计开关打开,才可以在系统表 SYS_AUDITTRAIL 中查看到审计信息。

安全审计机制将特定用户或特定对象相关的操作记录到系统审计日志中,作为后续对操作的查询分析和追踪的依据。通过审计机制,可以约束用户可能的恶意操作。

4.5 数据加密

数据库的安全性归根结底是要保护数据的安全,特别是高度敏感性数据,例如财务数据、军事数据、国家机密数据等。除前面介绍的安全性措施外,还可以采用数据加密技术。数据加密是防止数据库数据在存储和传输中失密的有效手段。加密的基本思想是根据一定的算法将原始数据——明文 (plaintext) 经过一系列复杂的计算,变换为不可直接识别的格式——密文 (ciphertext),从而使不知道解密算法的人无法获知数据的内容。

数据加密主要包括存储加密和传输加密。

1. 存储加密

存储加密一般有透明和非透明两种方式。透明存储加密是内核级加密保护方式,对用户完全隐蔽;非透明存储加密则是通过多个加密函数实现的。

透明存储加密是数据在写到磁盘时对数据进行加密,授权用户读取数据时再对其进行解密。由于数据加密对用户隐蔽,即用户不知道数据是被加密的密文,数据库的应用程序不需要做任何修改,只需在创建表语句中说明需加密的字段即可。当对加密数据进行增加、删除、修改和查询操作时,数据库管理系统将自动对数据进行加密、解密工作。基于数据库内核的数据存储加密、解密方法性能较好,安全性较高。

2. 传输加密

数据库在使用过程中通过网络传输登录系统的信息、SQL 语句和数据,若采用明文方式传输,容易被网络中的恶意用户截获或篡改,存在安全隐患。为了保证这些信息能够安全地进行交换和传输,数据库管理系统提供了传输加密功能。常用的传输加密方式如链路加密和端到端加密。其中,链路加密对传输数据在链路层进行加密,它的传输信息由报头和报文两部分组成,前者是路由选择信息,后者则是传送的数据信息。这种方式对报文和报头均加密。相对地,端到端加密对传输数据在发送端加密、接收端解密。它只加密报文,不加密报头。与链路加密相比,它只在发送端和接收端需要密码设备,而中间节点不需要密码设备,因此它所需的密码设备数量相对较少。但这种方式不加密报头,从而容易被非法监听者发现并从中获取敏感信息。

图 4.5 是一种基于安全套接层协议 (secure socket layer protocol, SSL protocol) 的数据库管理系统可信传输方案。它采用的是一种端到端的传输加密方式。在这个方案中,通信双方协商建